Résilience Alpha

Dossier d’ingénierie et de gouvernance

Projet Résilience Alpha

Cyber résilience et reprise autonome d’une plateforme de paiement fictive

GROUPE 3

Développement et remédiation	**Bissane TANOUTI**
Infrastructure et cybersécurité	**Theodore EFOLET BALLA**
Intelligence artificielle et gouvernance	**Ghita ALAMI**

Workshop national Bac + 5 | Session octobre 2026

Synthèse du démonstrateur

Nous avons construit une plateforme de paiement fictive capable de détecter un incident contrôlé, d'appliquer une réponse limitée à des actions autorisées et de vérifier la reprise par une transaction réelle. Le démonstrateur associe les cinq domaines imposés : développement, infrastructure, intelligence artificielle, cybersécurité et gouvernance.

La preuve de reprise ne repose pas uniquement sur l'état du conteneur. Le moteur contrôle l'authentification, exécute un paiement technique, vérifie la santé de l'API et confirme l'invariant comptable de 100 000 EUR. Lors des cinq cycles de panne testés, l'API de paiement est revenue à un état utilisable sans correction humaine, avec une durée totale comprise entre 6 et 9 secondes.

Objectifs et périmètre

Objectif	Réponse apportée	Preuve
Traiter une transaction fictive	Front React, Auth JWT, API Node.js et PostgreSQL	Tests API et contrôle d'intégrité
Observer l'incident	Prometheus, cAdvisor, Alloy, Loki et Grafana	Métriques, journaux JSON et règles SIEM
Détecter une anomalie	Isolation Forest alimenté par les signaux du démonstrateur	Score et alerte JSON vers la remédiation
Réagir automatiquement	Politique fermée de blocage, limitation, redémarrage et vérification	Incidents RESOLVED et cycles répétés
Gouverner la résilience	Analyse EBIOS RM, objectifs PCA PRA et lecture NIS2 DORA	Risques, responsabilités et limites documentés

Principales décisions

- Un seul point d'entrée public, le WAF, protège l'application et masque les services internes.
- Les réseaux Docker séparent les flux applicatifs, les données, l observabilité, l'IA et l'accès Docker de remédiation.
- Le moteur de remédiation ne reçoit jamais le socket Docker directement et ne peut redémarrer qu' une liste blanche de services.
- Les secrets en clair restent hors Git ; SOPS et age protègent la version partageable.
- Une alerte inconnue est escaladée et ne provoque aucune action automatique.

Sommaire

Synthèse du démonstrateur 2
Sommaire 3
1. Architecture et flux 4
2. Services métier et intégrité des données 5
3. Chaîne de détection et de reprise 6
4. Infrastructure observabilité et cybersécurité 7
5. Intelligence artificielle et assistant opérateur 8
6. Résultats des essais 9
7. Analyse des risques selon EBIOS Risk Manager 10
8. PCA/PRA et conduite de la reprise 11
9. NIS2 DORA et gouvernance 13
10. Organisation contributions et maîtrise 14
Annexe A : Contrats et points d'accès 15
Annexe B : Procédure de preuve 16
Annexe C : Références 17

1. Architecture et flux

L'architecture suit un principe simple : exposer le minimum et conserver les dépendances sensibles sur des réseaux internes. Le WAF reçoit les requêtes HTTP, transmet l'interface au front et route les appels d'authentification et de paiement. Auth et API accèdent à PostgreSQL sur un réseau de données distinct.

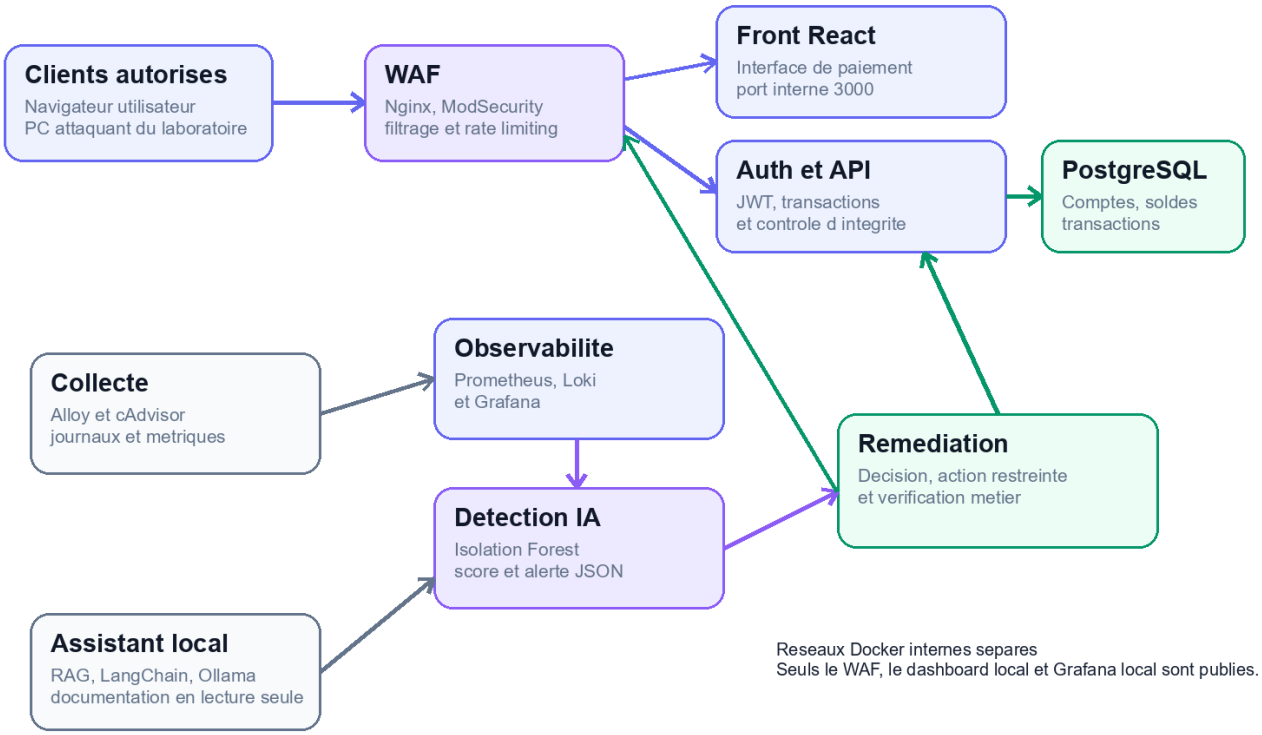


Figure 1 : Architecture logique et chaîne de reprise

Flux critiques

Flux	Origine vers destination	Contrôle
Paiement	Navigateur vers WAF vers API	JWT, validation stricte, idempotence
Authentification	Navigateur vers WAF vers Auth	bcrypt, JWT court, rate limiting
Données	Auth et API vers PostgreSQL	Réseau interne, contraintes SQL
Télémétrie	Services vers Alloy Prometheus Loki	Proxy Docker en lecture seule
Alerte	Detector vers Remediation	Contrat JSON et types autorisés
Action	Remediation vers proxy Docker	Réseau dédié, liste blanche, verbes filtrés

Les ports publiés sont limités au WAF sur le port 80, au dashboard sur 127.0.0.1:8088 et à Grafana sur 127.0.0.1:3001. PostgreSQL, Prometheus, Loki, le détecteur et les proxies Docker ne sont pas exposés au réseau du campus.

2. Services métier et intégrité des données

Parcours utilisateur

1. L'utilisateur saisit son identifiant et son mot de passe dans le front React.
2. Auth compare le mot de passe haché avec bcrypt et émet un JWT valable quinze minutes.
3. Le front demande les comptes associés à l'identité portée par le jeton.
4. L'API valide le compte débité, le bénéficiaire, le montant, la devise et la clé d idempotence.
5. PostgreSQL verrouille les comptes, applique le transfert et écrit l'historique dans une transaction SQL atomique.

Composants applicatifs

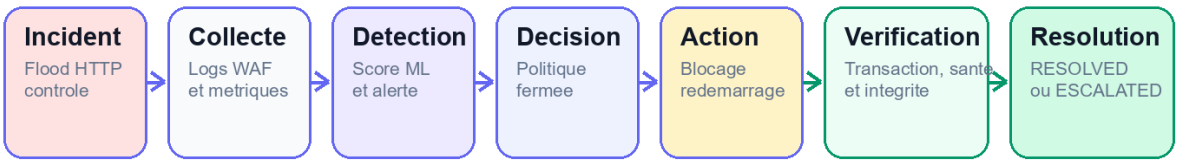
Service	Responsabilité	Mesures de fiabilité et sécurité
Front	Connexion, consultation des comptes, création de paiements	Jeton uniquement en mémoire, appels relatifs via le WAF
Auth	Création et vérification des JWT	Bcrypt, comparaison factice, journaux JSON
Api-paiement	Transactions, soldes, santé et intégrité	Transactions SQL, contrôles d'accès, idempotence
Postgres	Persistance des utilisateurs, comptes et paiements	Contraintes, volume persistant, réseau data interne
Dashboard	Etat des services, incidents et paiement de contrôle	Exposé seulement sur la boucle locale du PC hôte

Invariant comptable et preuve de reprise

Les six comptes fictifs totalisent 100 000 EUR. Chaque paiement déplace une somme sans créer ni supprimer de valeur. L'endpoint d'intégrité confirme le total attendu et l'absence de solde négatif. Une clé d idempotence unique empêche un double débit lorsque la même demande est rejouée après une interruption.

Contrôle	Réponse attendue	Risque réduit
Transaction SQL atomique	Tout est validé ou tout est annulé	Solde partiellement mis à jour
Verrouillage dans un ordre fixe	Comptes protégés pendant le transfert	Course concurrente et interblocage
Clé d idempotence	Deuxième demande refusée avec 409	Double paiement
GET integrity	Consistent true et total 100000	Reprise technique sans cohérence métier

3. Chaîne de détection et de reprise



Principe de gouvernance : aucune alerte inconnue ne declenche une action privilegiee.

Figure 2 : Séquence automatisée de l'incident à la vérification

Détection

Le détecteur exploite un modèle Isolation Forest. Ce modèle apprend la forme générale du trafic normal sans nécessiter une étiquette pour chaque attaque. Les observations combinent notamment le débit de requêtes, la latence, les erreurs et les ressources du service. Un score anormal déclenche une alerte JSON vers le moteur de remédiation.

Politique de décision

Type	Actions autorisées	Décision de sûreté
DoS	Blocage IP, limitation, redémarrage si dégradé, vérification	Restaure la disponibilité
Bruteforce	Blocage IP puis vérification	Protège l'authentification
Sqli	Blocage IP puis vérification	Maintient le filtrage applicatif
Unknown	Aucune action automatique	Escalade vers un opérateur

Vérification métier

Le moteur ne classe un incident RESOLVED qu'après quatre contrôles : connexion du compte technique monitor, nouvelle transaction fictive, état de santé positif et contrôle d'intégrité cohérent. Les vérifications sont répétées pendant le redémarrage pour distinguer un délai normal d'un échec durable.

Limite de la reprise autonome

Le mécanisme traite une perte de disponibilité dans le périmètre du laboratoire. Il ne prouve pas qu'une compromission, une exfiltration ou une altération historique est corrigée. Ces scénarios exigeraient confinement, investigation, rotation des secrets et restauration depuis une sauvegarde saine.

4. Infrastructure observabilité et cybersécurité

Déploiement reproductible

Docker Compose décrit quinze services, leurs dépendances, réseaux, volumes, limites de ressources et contrôles de santé. Ansible valide la configuration, construit et démarre la stack, attend les services et contrôle les points d'accès. Cette automatisation réduit les écarts entre le PC de développement et le PC hôte de démonstration.

Chaîne d observabilité

Composant	Rôle dans le démonstrateur	Donnée produite ou consommée
Prometheus	Collecte et conserve les métriques	Débit, latence, erreurs, santé
cAdvisor	Mesure les ressources des conteneurs	CPU et mémoire
Grafana Alloy	Découvre les conteneurs et collecte leurs logs	Journaux standardisés
Loki	Centralise et recherche les journaux	Logs JSON WAF et services
Grafana	Visualise les signaux et évalue les alertes	Dashboards et règles SIEM

Mesures de sécurité

- WAF Nginx et ModSecurity avec OWASP Core Rule Set, blocage SQLi et XSS, limitation de débit et journaux exploitables.
- Services applicatifs non root, systèmes de fichiers en lecture seule, capacités Linux retirées et no new privileges.
- Segmentation des réseaux Docker et publication minimale des ports.
- Deux proxies Docker séparés : lecture seule pour Alloy et redémarrage restreint pour la remédiation.
- SOPS et age pour chiffrer les secrets versionnés ; fichier .env local ignoré par Git.
- Rotation des journaux Docker pour limiter l'occupation du disque pendant les essais.

Fonction SIEM

Trois règles Grafana corrèlent les logs Loki du WAF : rafale de réponses 429, répétition de réponses 403 et hausse des erreurs 5xx. Ces règles donnent une lecture de sécurité au dispositif d observabilité sans déployer une Elastic Stack trop coûteuse pour le PC hôte.

5. Intelligence artificielle et assistant opérateur

Modèle de détection

Isolation Forest isole les observations rares en construisant plusieurs arbres aléatoires. Une observation qui est séparée rapidement reçoit un caractère plus anormal. L'approche convient au sprint parce qu'elle s'entraîne rapidement, fonctionne avec peu de données et produit un score exploitable par une politique de décision explicite.

Étape	Traitement	Point de maîtrise
Constitution	Trafic normal et flood contrôlé	Données entièrement fictives
Préparation	Fenêtres de métriques et normalisation cohérente	Même schéma en apprentissage et en exécution
Inférence	Score calculé sur les observations récentes	Seuil documenté et journalisé
Transmission	Alerte JSON vers remediation	Type, service, score, IP, caractéristiques et date
Réaction	Politique fermée du moteur	Le modèle ne reçoit aucun privilège Docker

Assistant RAG local

L'assistant associe LangChain, une recherche documentaire de type RAG et un modèle local servi par Ollama. Il retrouve des passages du contrat, du README et des procédures avant de formuler une réponse. Le modèle reste inférieur ou égal à huit milliards de paramètres et n'accède qu au dossier de documentation monté en lecture seule.

Le RAG aide l'opérateur à comprendre une alerte ou retrouver une procédure. Il ne commande pas la remédiation, ne lit pas la base de paiement et ne détient aucun secret. Cette séparation évite qu'une réponse probabiliste déclenche directement une action privilégiée.

Limites du lot IA

- Les données du workshop couvrent peu de situations et ne représentent pas la diversité d'une production financière.
- Le seuil peut créer des faux positifs ou manquer une attaque lente ; son suivi doit comparer précision, rappel et coût opérationnel.
- Un RAG peut citer un passage inadéquat ou produire une réponse inexacte ; les sources récupérées doivent rester visibles.
- La décision de redémarrer appartient à une politique déterministe, pas au modèle de langage.

6. Résultats des essais

Les essais couvrent le métier, le WAF, le durcissement et la reprise. Ils sont exécutés sur la stack Docker locale avec des données et des adresses fictives.

Essai	Résultat	Interprétation
API Auth Dashboard	16 contrôles réussis	Authentification, paiements, erreurs, soldes et intégrité
WAF	5 contrôles réussis sur 5	Santé, routage, SQLi et XSS
Flood HTTP	300 requêtes, 192 HTTP 200, 108 HTTP 429, 0 erreur réseau	Le rate limiting est observable
Durcissement	Contrôles réussis	Ports, utilisateur, capacités et privilèges maîtrisés
Proxies Docker	Lecture 200, actions interdites 403	Séparation lecture seule et remédiation
Incident inconnu	ESCALATED sans action	Comportement sûr par défaut

Cinq cycles de panne et reprise

Cycle	État final	Durée moteur	Durée totale	Vérification
1	RESOLVED	5 960 ms	7 s	Transaction, santé et intégrité
2	RESOLVED	6 127 ms	7 s	Transaction, santé et intégrité
3	RESOLVED	5 997 ms	8 s	Transaction, santé et intégrité
4	RESOLVED	3 750 ms	6 s	Transaction, santé et intégrité
5	RESOLVED	7 037 ms	9 s	Transaction, santé et intégrité

Résultat global : 5 reprises réussies sur 5, sans intervention corrective humaine. Le temps total médian est de 7 secondes. Les premières vérifications peuvent échouer pendant que l'API redémarre ; la tentative suivante confirme ensuite le retour effectif du service.

Lecture critique

Ces résultats démontrent la chaîne prévue pour une panne contrôlée. Ils ne mesurent ni une charge prolongée, ni une perte du disque hôte, ni une corruption volontaire de la base. La reproductibilité doit être confirmée sur le PC hôte et depuis le PC attaquant avant le jury.

7. Analyse des risques selon EBIOS Risk Manager

L'analyse applique une version proportionnée des ateliers EBIOS Risk Manager de l ANSSI [1]. La valeur métier prioritaire est la capacité à accepter un paiement fictif exact et traçable. Les événements redoutés sont l'indisponibilité, l'altération d'une transaction, l'accès non autorisé et la perte de capacité d'investigation.

Risque	Vraisemblance	Impact	Mesures existantes	Risque résiduel
Flood rendant l'API indisponible	Élevée	Élevé	WAF, rate limit, détection, reprise	Moyen
Injection ou XSS	Moyenne	Élevé	CRS, schémas JSON, requêtes paramétrées	Faible à moyen
Abus du moteur de remédiation	Moyenne	Critique	Proxy filtré, réseau dédié, liste blanche	Moyen
Secret exposé dans Git	Moyenne	Élevé	SOPS age, gitignore, procédure de rotation	Faible à moyen
Corruption ou perte de PostgreSQL	Faible à moyenne	Critique	Transactions, contraintes, volume persistant	Élevé sans sauvegarde
Faux positif du détecteur	Moyenne	Moyen	Score journalisé, actions fermées, escalade unknown	Moyen
Perte des journaux	Faible à moyenne	Élevé	Loki, volumes, rotation locale	Moyen

Scénarios stratégiques

- Un acteur externe sature le point d'entrée afin d'empêcher les paiements et de dégrader la confiance des partenaires.
- Un attaquant exploite une entrée applicative pour lire ou modifier des données fictives.
- Un composant interne compromis tente d'utiliser les privilèges de remédiation pour agir sur d'autres conteneurs.
- Une erreur de configuration ou une perte matérielle rend les données indisponibles au-delà de la capacité de redémarrage automatique.

Priorités de traitement

La première priorité est de sauvegarder PostgreSQL et de tester une restauration, car le volume persistant ne protège pas d'une perte du disque. La deuxième est d'authentifier les alertes reçues par le moteur. La troisième est de persister l'historique de remédiation hors mémoire afin de conserver une preuve après redémarrage.

8. PCA/PRA et conduite de la reprise

Le PCA maintient les fonctions essentielles pendant une perturbation ; le PRA décrit le retour à un état utilisable après interruption. Les objectifs ci-dessous sont adaptés au démonstrateur et ne constituent pas des engagements de production.

Fonction	Criticité	Objectif RTO	Objectif RPO	Mécanisme
Paiement et authentification	Critique	30 s pour panne conteneur	0 pour panne conteneur	Restart, volume PostgreSQL, vérification métier
WAF et front	Élevée	5 min	Sans objet	Recréation Compose et configuration versionnée
Détection et remédiation	Élevée	5 min	Historique non garanti	Recréation, contrat d'alerte, politique versionnée
Observabilité	Moyenne	15 min	Journaux récents selon volume	Volumes Loki Grafana Prometheus
Assistant RAG	Faible	4 h	Documents Git	Reconstruction de l'index

Procédure de reprise du scénario démontré

1. Le WAF et la télémétrie rendent visible l'anomalie.
2. Le détecteur émet une alerte structurée avec le service, le score et les caractéristiques observées.
3. Le moteur vérifie le type d'incident et la cible contre ses listes autorisées.
4. Les actions de confinement puis de restauration sont journalisées.
5. Le compte monitor exécute une transaction et contrôle santé et intégrité.
6. Le dashboard affiche RESOLVED ; sinon l'incident passe à FAILED ou ESCALATED.

Responsabilités en crise

Activité	Responsable	Appui	Preuve attendue
Déclenchement de l'attaque autorisée	Theodore	Bissane	Commande et heure de début
Supervision de la transaction	Bissane	Theodore	Etat métier avant et après
Lecture du score et des limites IA	Ghita	Theodore	Score, variables et alerte
Décision d'escalade	Groupe	Coach	Incident inconnu ou vérification échouée

Activité	Responsable	Appui	Preuve attendue
Communication au jury	Groupe	Chacun sur son domaine	Chronologie commune

Retour au fonctionnement normal

Après le test, l'équipe vérifie tous les healthchecks, retire uniquement les IP fictives ajoutées pendant la démonstration, confirme l'invariant comptable et archive les journaux utiles. Une réinitialisation avec suppression des volumes n est utilisée qu'en connaissance de la perte des données de démonstration.

9. NIS2 DORA et gouvernance

NIS2 demande notamment une gestion des risques, le traitement des incidents, la continuité, la sécurité de la chaîne d'approvisionnement, l'évaluation des mesures et l'usage approprié de la cryptographie [2]. DORA applique au secteur financier un cadre de gouvernance du risque TIC, de continuité, de notification, de tests de résilience et de maîtrise des prestataires [3].

Le démonstrateur est un exercice académique et ne permet pas de conclure à la conformité d'une organisation réelle. L'assujettissement dépendrait du statut juridique, du secteur, de la taille et des services fournis. Les textes servent ici de références de conception.

Thème	Élément du projet	Écart pour un contexte industriel
Gouvernance du risque TIC	EBIOS, responsabilités et arbitrages documentés	Validation par la direction, contrôle indépendant et audits
Détection et notification	Logs, alertes et chronologie locale	Classification réglementaire, délais et destinataires officiels
Continuité et reprise	PCA PRA et cinq cycles réussis	BIA complet, sites redondants, sauvegardes et exercices réguliers
Tests de résilience	Flood, injection, panne et tests automatisés	Programme annuel fondé sur le risque et tests indépendants
Prestataires TIC	Images Docker et outils open source identifiés	Registre contractuel, dépendances et stratégie de sortie
Protection des secrets	SOPS age et séparation des accès	KMS ou Vault, rotation automatisée et contrôle d'accès centralisé

Arbitrages retenus

- Prioriser une chaîne de bout en bout démontrable plutôt qu' une haute disponibilité incomplète.
- Conserver le modèle IA sans privilège et confier les actions à une politique déterministe.
- Utiliser Loki et Grafana comme fonction SIEM proportionnée aux ressources du PC hôte.
- Limiter l'exposition réseau plutôt que publier chaque service pour faciliter les tests.

Recommandations à la direction

Avant une mise en production, la direction devrait financer une base répliquée et sauvegardée, un gestionnaire de secrets centralisé, une authentification forte, une journalisation durable, une validation signée des alertes et un programme de tests réguliers. Les indicateurs de pilotage devraient suivre le temps de détection, le temps de reprise, le taux de vérification métier réussie et les faux positifs du détecteur.

10. Organisation contributions et maîtrise

Membre	Responsabilité principale	Contributions défendables
Bissane TANOUTI	Développement et remédiation	Front React Tailwind, Auth JWT, API de paiement, PostgreSQL, dashboard, moteur et vérification métier
Theodore EFOLET BALLA	Infrastructure et cybersécurité	Compose, Ansible, WAF, Prometheus, Grafana, Loki, Alloy, SOPS, attaque contrôlée, durcissement et tests répétés
Ghita ALAMI	IA et gouvernance	Isolation Forest, données et seuil, detector, RAG local, EBIOS RM, PCA PRA et analyse NIS2 DORA

Mode de collaboration

Le groupe a figé un contrat commun pour les ports, endpoints, métriques, alertes et actions. Chaque fonctionnalité a été développée sur une branche, relue par pull request puis intégrée à main. La règle de qualité était qu un merge ne devait pas empêcher docker compose up de démarrer.

Usage des outils d'IA générative

Des assistants d IA ont aidé à accélérer la rédaction de code, la configuration et la documentation. Le groupe a conservé la responsabilité des résultats : build de chaque image, tests automatisés, lecture des journaux, corrections de routage et essais répétés sur la stack réelle. Aucun secret en clair n'a été transmis ni ajouté au dépôt.

Limites techniques connues

- Architecture à nœud unique sans réplication de PostgreSQL ni bascule du PC hôte.
- Historique de remédiation conservé en mémoire et perdu au redémarrage du moteur.
- Blocage dynamique du WAF et rechargement de configuration à fiabiliser pour une exploitation continue.
- Jeu de données IA réduit et absence de mesure longue durée des dérives du modèle.
- Assistant RAG sans évaluation formelle de fidélité des réponses.
- cAdvisor sous Docker Desktop fournit une vision moins détaillée que sur un hôte Linux natif.

Conclusion

Le démonstrateur répond au scénario central du sujet : une attaque contrôlée produit des signaux observables, le système prend une décision bornée, rétablit le service et prouve la reprise par une opération métier. Les essais montrent une reprise répétable sur le périmètre prévu. Les principales priorités industrielles seraient la protection durable des données, la haute disponibilité, l'authentification des alertes et la gouvernance continue des modèles et des accès privilégiés.

Annexe A : Contrats et points d'accès

Interface	Usage	Exposition
http://PC_HOTE/	Front de paiement derrière le WAF	Hotspot autorisé
POST /auth/login	Authentification de l'utilisateur	Via WAF
POST /api/transactions	Création d'un paiement	Via WAF avec JWT
GET /api/health	Santé de l'API	Via WAF
GET /integrity	Invariant comptable	Réseau interne avec JWT monitor
POST remediation:5000/incidents	Réception d'une alerte	Réseau app interne
http://127.0.0.1:8088	Dashboard de résilience	PC hôte uniquement
http://127.0.0.1:3001	Grafana	PC hôte uniquement

Format de l'alerte

{"incident_id":"INC-...","type":"dos","service":"api-paiement","score":0.93,"source_ip":"192.168.137.20","features":{"req_rate":850,"p95_latency":2.4,"error_rate":0.31},"ts":"..."}

Etats du moteur

DETECTED vers DECIDED vers ACTING vers VERIFYING vers RESOLVED ou FAILED. Un type inconnu est dirigé vers ESCALATED sans action automatique.

Métriques principales

Métrique	Interprétation
http_requests_total	Nombre de requêtes par service, route et statut
http_request_duration_seconds	Distribution de latence et calcul du p95
transactions_total	Paiements terminés ou refusés
db_up	Disponibilité de PostgreSQL vue par le service
container_cpu_usage_seconds_total	Consommation CPU des conteneurs
container_memory_usage_bytes	Mémoire utilisée par les conteneurs
remediation_incidents_total	Incidents par type et état

Annexe B : Procédure de preuve

Préparation

1. Vérifier que main est synchronisé et que le fichier .env local contient les secrets requis.
2. Exécuter docker compose config puis docker compose up avec reconstruction si nécessaire.
3. Contrôler docker compose ps et les trois points d'accès publiés.
4. Afficher le dashboard, Grafana et le front sur le PC hôte.

Tests à conserver

Test	Commande ou script	Résultat attendu
WAF	tests/waf-smoke.ps1	5 réussites, 0 échec
API	tests/smoke-api.sh	Tous les contrôles passent
Durcissement	tests/container-hardening.ps1	Aucun contrôle en échec
Proxies Docker	tests/docker-proxy-smoke.ps1	Lectures autorisées, écritures non prévues refusées
Restauration	tests/restoration-cycles.ps1	5 cycles terminés et API saine
Remédiation	tests/remediation-test.sh repeat 5	5 incidents RESOLVED
Flood	attack/http-flood.ps1	Réponses 429 visibles et alerte Grafana

Séquence du Clip Chrono

Temps	Image attendue	Preuve
0 à 10 s	Service sain et transaction possible	Dashboard vert
10 à 25 s	Lancement du flood depuis le PC attaquant	Terminal visible
25 à 40 s	Anomalie et incident	Alerte, score ou logs
40 à 52 s	Action et retour du service	Incident en cours puis RESOLVED
52 à 60 s	Nouvelle transaction réussie	Paiement et contrôle d'intégrité

La capture doit rester continue et sans coupe masquant une intervention corrective. Les titres ou sous titres peuvent expliquer l'étape sans interrompre la séquence.

Annexe C : Références

[1] ANSSI, La méthode EBIOS Risk Manager, guide et fiches méthode, https://cyber.gouv.fr/securisation/analyse-des-risques/methode-ebios-rm/ au 22 octobre 2026.

[2] Union européenne, Directive UE 2022 2555 dite NIS2, notamment articles 21 et 23, EUR Lex au 22 octobre 2026.

[3] Union européenne, Règlement UE 2022 2554 dit DORA, notamment articles 5 à 14 et 24 à 27, EUR Lex au 22 octobre 2026.

[4] EPSI Direction Pédagogique Nationale, Sujet de Workshop Bac plus 5 Project Resilience Alpha, session octobre 2026.

[5] Dépôt du groupe 3, README, contrat d'interface, configurations Docker Compose, procédures et scripts de test, version du 22 octobre 2026.

Traçabilité des décisions

Décision	Justification	Élément vérifiable
WAF unique en entrée	Réduire la surface exposée	Ports publiés dans Compose
Proxy Docker filtré	Limiter le privilège du moteur	Tests 200 et 403
Vérification métier	Un restart ne prouve pas la reprise	Transaction monitor et intégrité
SOPS age	Protéger les secrets au repos dans Git	Fichier chiffré et scripts
Isolation Forest	Détection non limitée à des seuils codés en dur	Modèle, caractéristiques et score
RAG sans action	Séparer aide probabiliste et privilège	Montage docs en lecture seule